

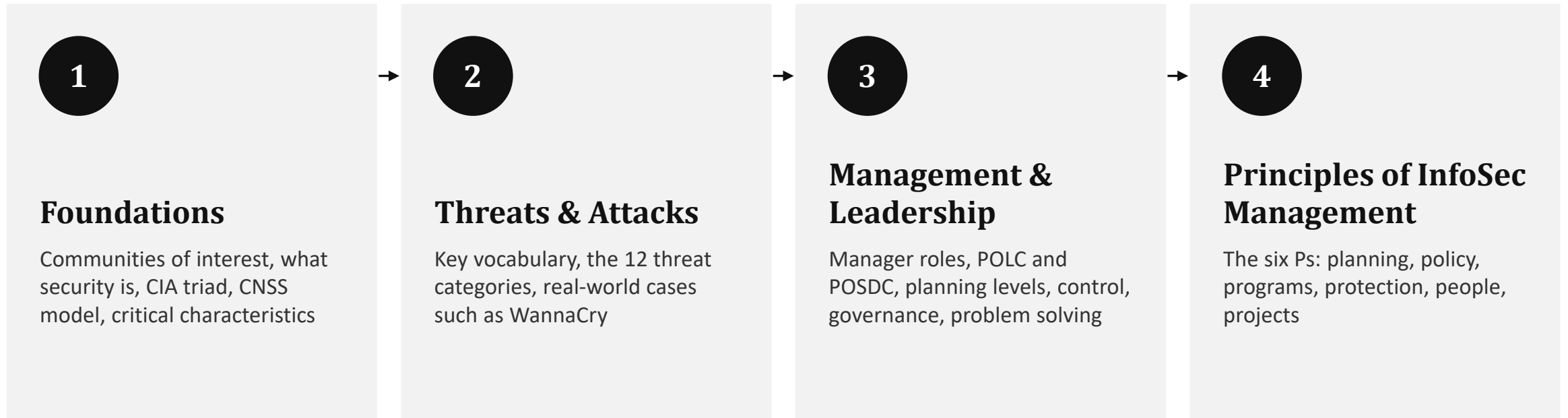
Introduction to the Management of Information Security

Security concepts, threats and attacks, management and leadership, and the six Ps of InfoSec management

Based on Whitman & Mattord, Management of Information Security, 6th ed., Ch. 1



Week 1 at a Glance



Hands-on lab block

Lab 1: Asset inventory & CIA classification · Lab 2: Integrity, authentication & password strength · Lab 3: Threat analysis case study & six Ps plan

Learning Objectives

1

List and discuss the key characteristics of information security

2

List and describe the dominant categories of threats to information security

3

Discuss the key characteristics of leadership and management

4

Describe the importance of the manager's role in securing an organization's information assets

5

Differentiate information security management from general business management



How you will show it

- Short knowledge checks during the lecture
- Lab 1: classify real assets using the CIA triad
- Lab 2: prove integrity with hashes and evaluate passwords
- Lab 3: analyze a breach case and draft a six Ps plan

Why This Matters: The Cost of Getting It Wrong

\$4.44M

Global average cost of a data breach in 2025

IBM Cost of a Data Breach Report 2025

\$10.22

M.
Average cost of a breach for U.S. organizations — an all-time high

IBM Cost of a Data Breach Report 2025

241

days
Average time to identify and contain a breach

IBM Cost of a Data Breach Report 2025

60%

Share of breaches that involved a human element

Verizon 2025 Data Breach Investigations Report



Takeaway: most of these costs come from detection, response, lost business and regulatory penalties — all of which are shaped by management decisions made long before an attack.

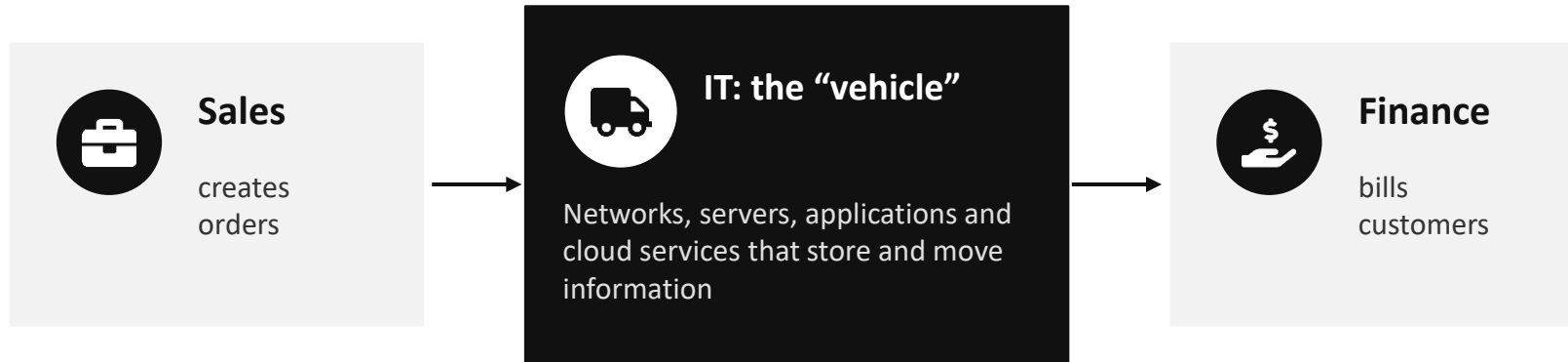
PART 1

Foundations of Information Security

Who is responsible for security, what security means, and the models we use to describe the value of information

01

Information: The Organization's Most Valuable Asset



Key ideas

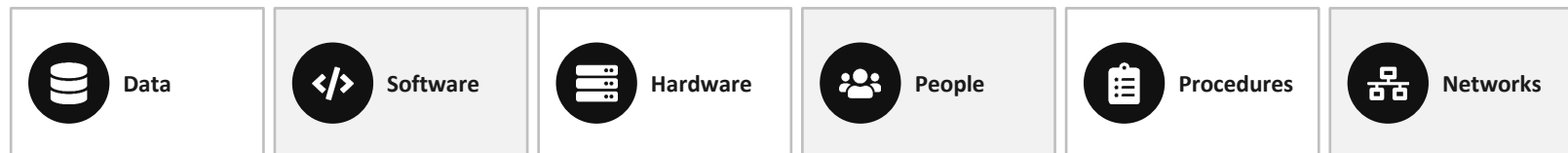
- IT stores and transports information between business units
- Astute managers see InfoSec as the mechanism that keeps those information assets secure
- Executive-level InfoSec managers (e.g., the CISO) create professionally managed security teams
- Their goal: protect information assets wherever — and whatever — they are



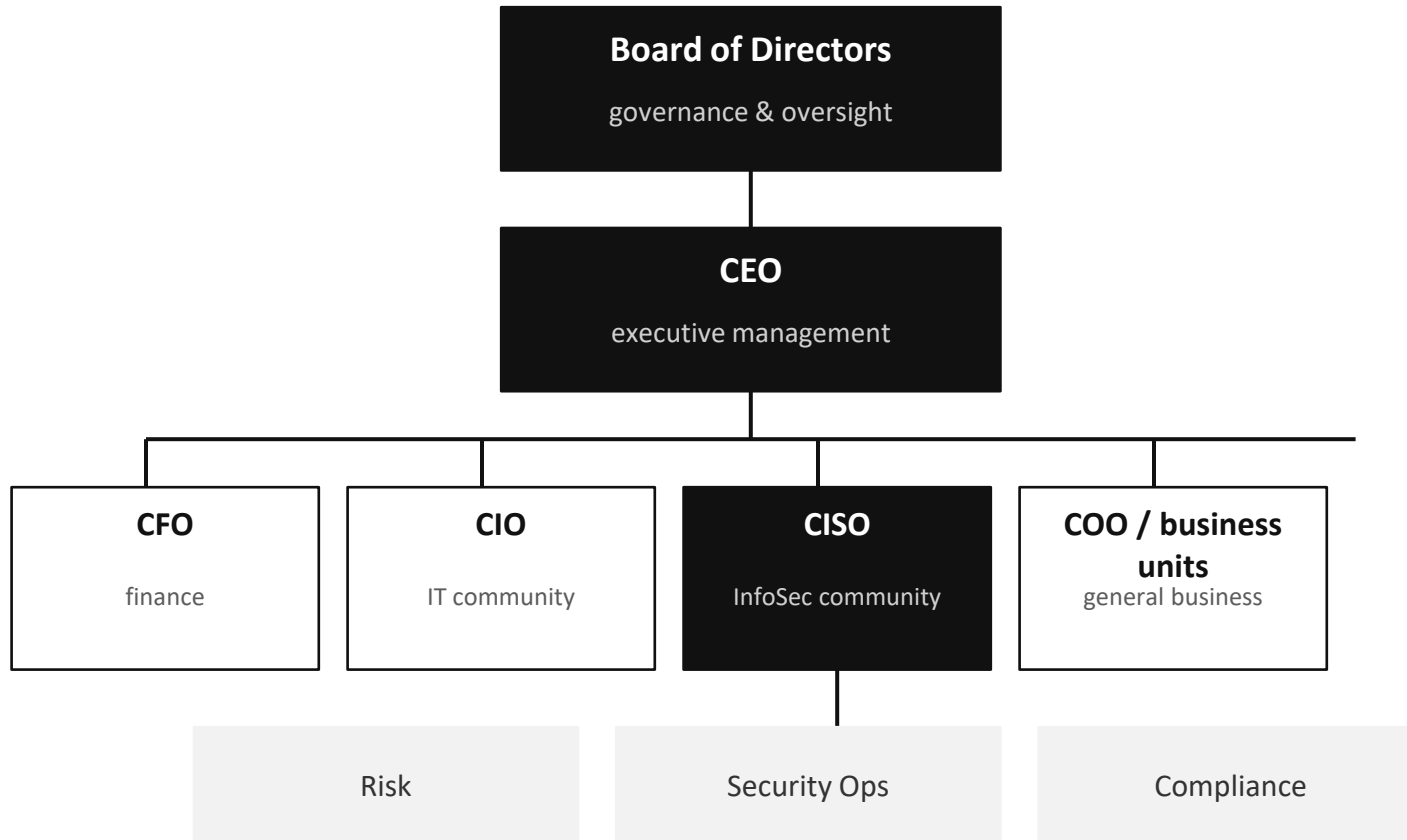
What happens if the vehicle breaks down — even for a little while?

Orders stop, invoices stall, customers leave. Information security protects the vehicle and the cargo.

THE SIX COMPONENTS OF AN INFORMATION SYSTEM — ALL ARE ASSETS TO PROTECT



Where Information Security Sits in the Organization

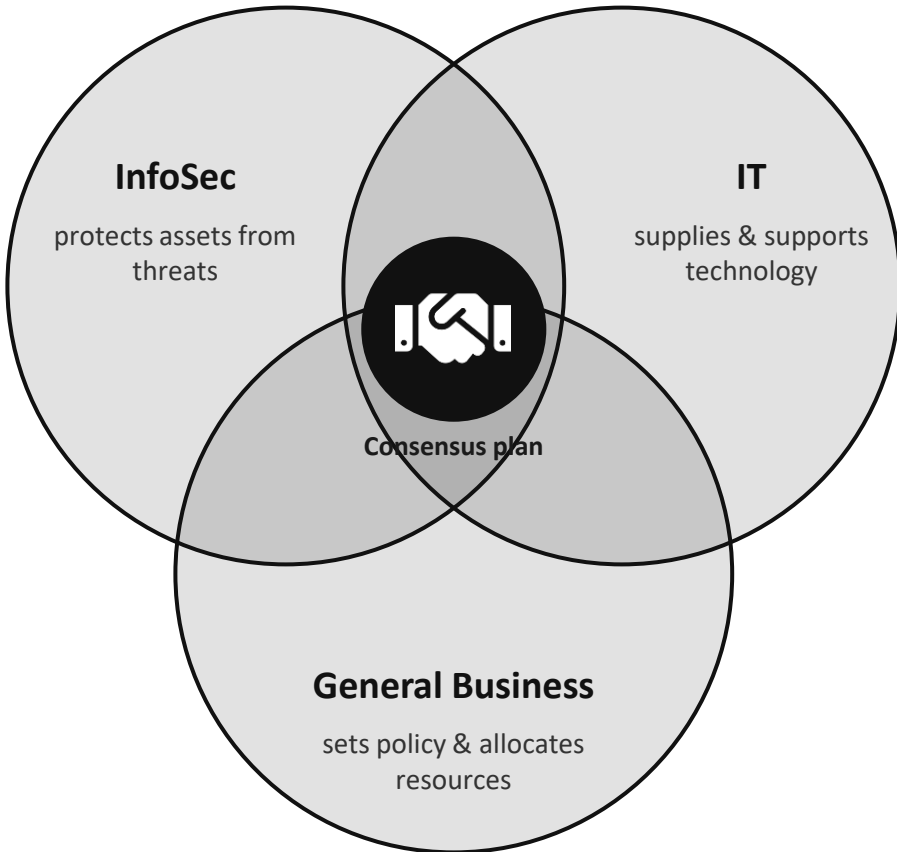


Reporting lines vary: in many firms the CISO reports to the CIO; in others to the CEO, CRO or general counsel.

Security decisions involve everyone

- Planning and funding decisions involve more than IT managers or the security team
- They must involve the entire organization, represented by three communities of interest:
 - Information security professionals
 - Information technology professionals
 - The rest of the organization (general business)

The Three Communities of Interest



Working together

- The three groups engage in a constructive effort to reach consensus on an overall plan to protect the organization's information assets
- Each community brings a different perspective — technical, protective and business
- Together they make recommendations to executive management on how to secure information assets most effectively
- No single community can succeed alone: security without business support lacks resources; business without security accepts unmanaged risk

What Each Community Contributes



Information Security

Protects information assets from threats

- Identifies threats and vulnerabilities
- Designs and monitors controls
- Leads incident response
- Educates and trains users

Example: sets the requirement that all remote access uses MFA



Information Technology

Supplies and supports IT that fits the organization's needs

- Builds and operates systems
- Applies patches and configurations
- Maintains availability and backups
- Implements technical controls

Example: rolls out the MFA solution to 2,000 laptops



General Business

Articulates policy and objectives; allocates resources

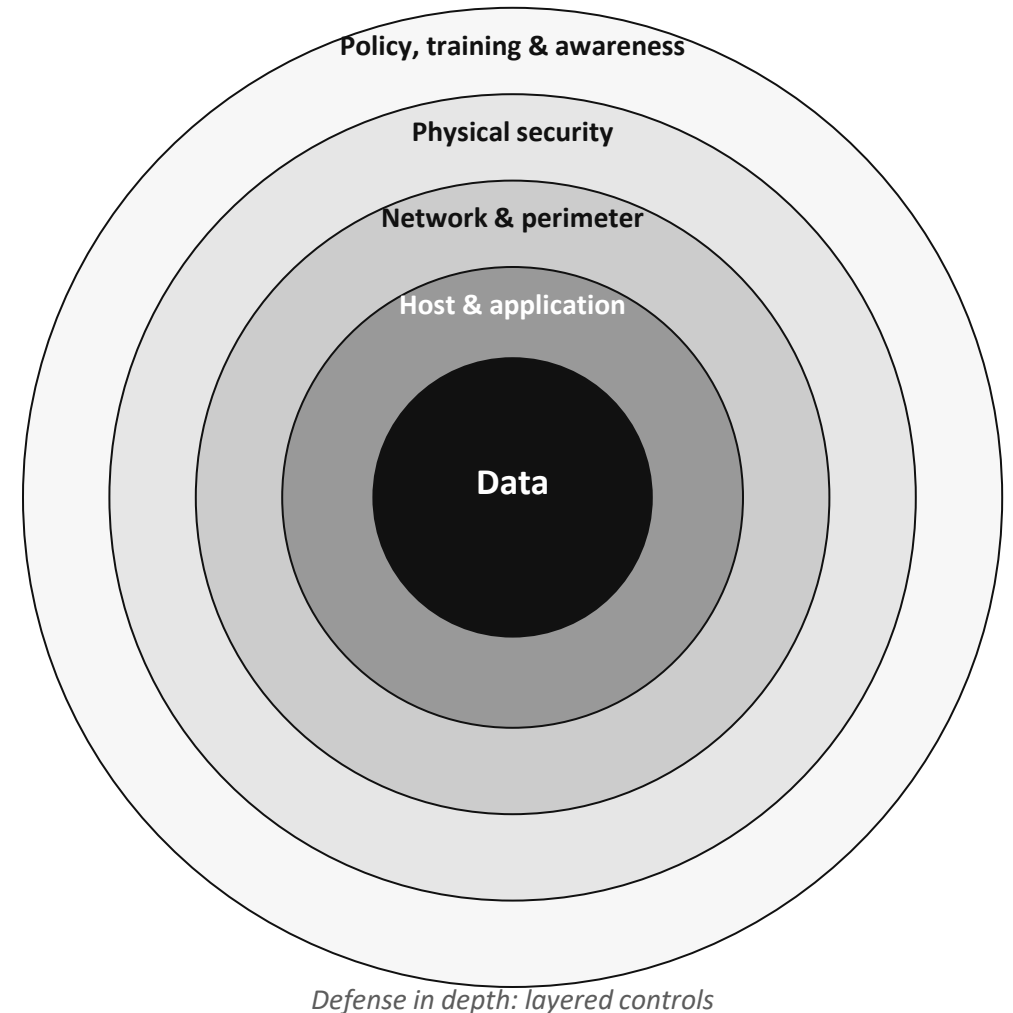
- Owns business processes and data
- Approves budgets and priorities
- Accepts or rejects residual risk
- Communicates policy to staff

Example: funds MFA and tells staff why it matters

What Is Security?

“Security” means being free from danger — protected from the risk of loss, damage, unwanted modification, or other hazards.

- **Multilayered:** an appropriate level of security depends on implementing several layers of protection
- **Multiple strategies:** security is achieved through strategies used simultaneously or in combination
- **Management’s role:** ensure each strategy is properly planned, organized, staffed, directed and controlled



Specialized Areas of Security



Physical security

Protects physical items, objects, facilities and people from unauthorized access and misuse

Badges, locks, guards, CCTV



Operations security

Protects the details of an organization's operations and activities

Need-to-know, change control



Communications security

Protects communications media, technology and content

Encrypted email, secure radio



Cyber (computer) security

Protects computerized information-processing systems and the data they hold

Endpoint protection, patching



Network security

Protects voice and data networking components, connections and content

Firewalls, segmentation, VPN

Information security draws on all five areas — it is the umbrella that protects information wherever it is stored, processed or transmitted.

Defining Information Security (InfoSec)

Information security focuses on the protection of information and the characteristics that give it value — such as confidentiality, integrity and availability — including the technology that houses and transfers that information, through policy, training and awareness programs, and technology.



WHAT is protected

Information and the characteristics that give it value

- Confidentiality
- Integrity
- Availability
- plus privacy, accountability, etc.



WHERE it lives

The technology that houses and transfers information

- Storage (at rest)
- Processing (in use)
- Transmission (in motion)

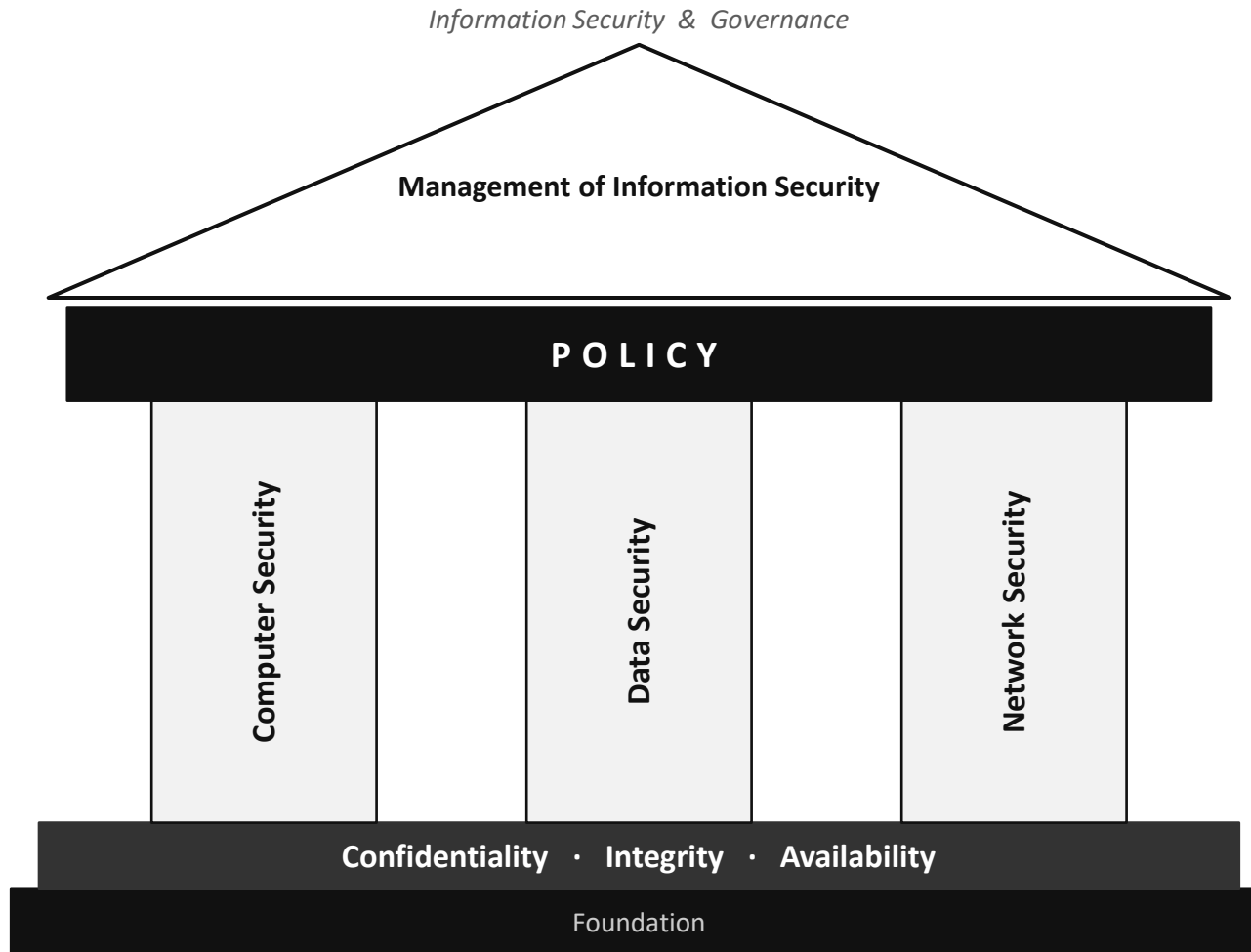


HOW it is protected

A variety of protection mechanisms

- Policy
- Training and awareness programs
- Technology

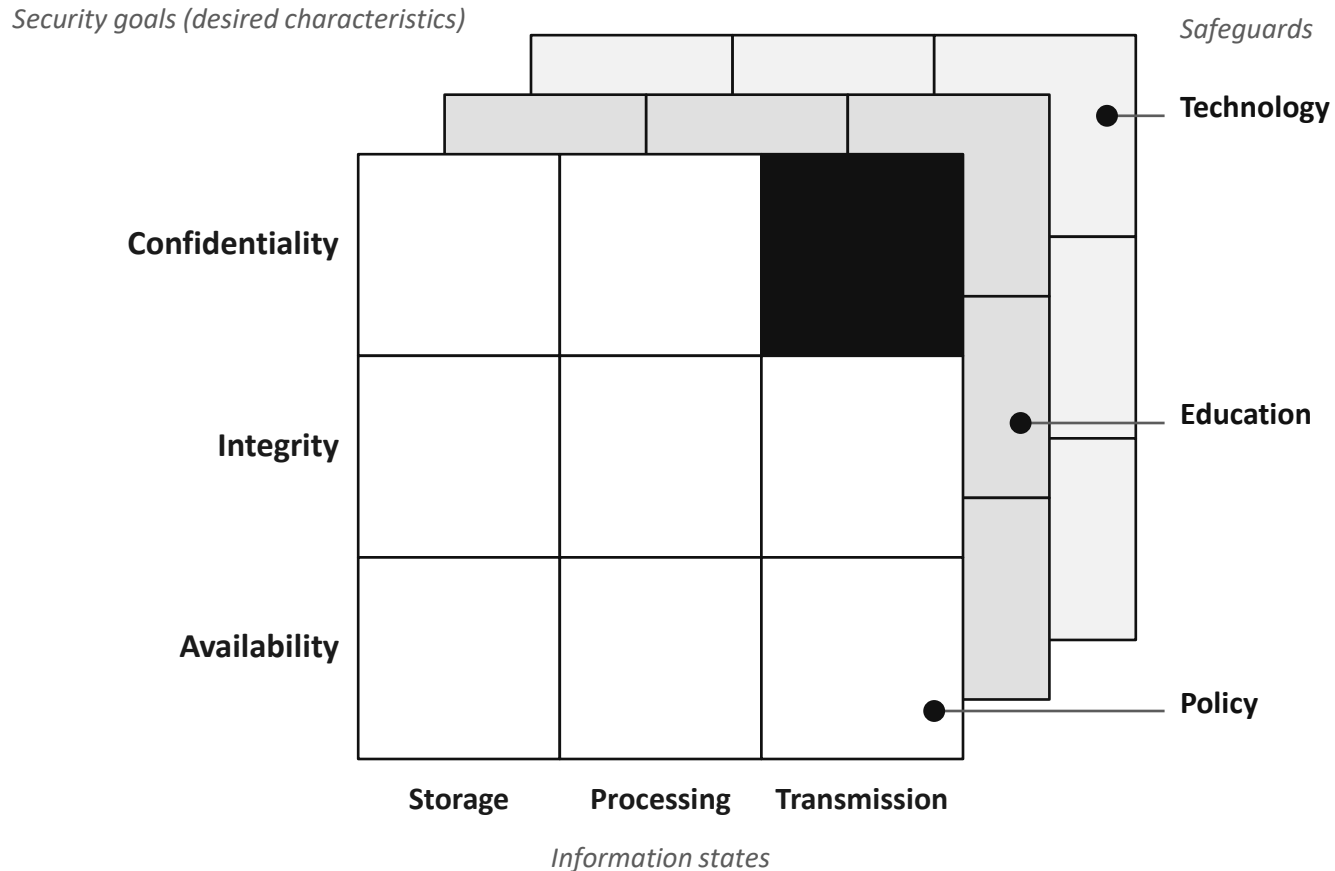
Components of Information Security



Reading the diagram

- **Foundation:** the C.I.A. characteristics everything else rests on
- **Pillars:** computer, data and network security carry the load
- **Policy:** ties the pillars together and directs how they are used
- **Roof:** management of information security, framed by InfoSec and governance, covers and protects the whole structure
- **Lesson:** remove any piece and the structure is weakened

The CNSS Security Model (McCumber Cube)



Highlighted cell: Confidentiality × Transmission × Policy

Three dimensions, 27 cells

- Also called the NSTISSI No. 4011 / CNSS model, after the U.S. Committee on National Security Systems
- **Axis 1 — goals:** confidentiality, integrity, availability
- **Axis 2 — states:** storage, processing, transmission
- **Axis 3 — safeguards:** policy, education, technology
- Each of the 27 cells is an area that a complete security program must address
- Example cell: a policy requiring that confidential data be encrypted whenever it is transmitted

Using the Cube — and Its Limitations



Strengths

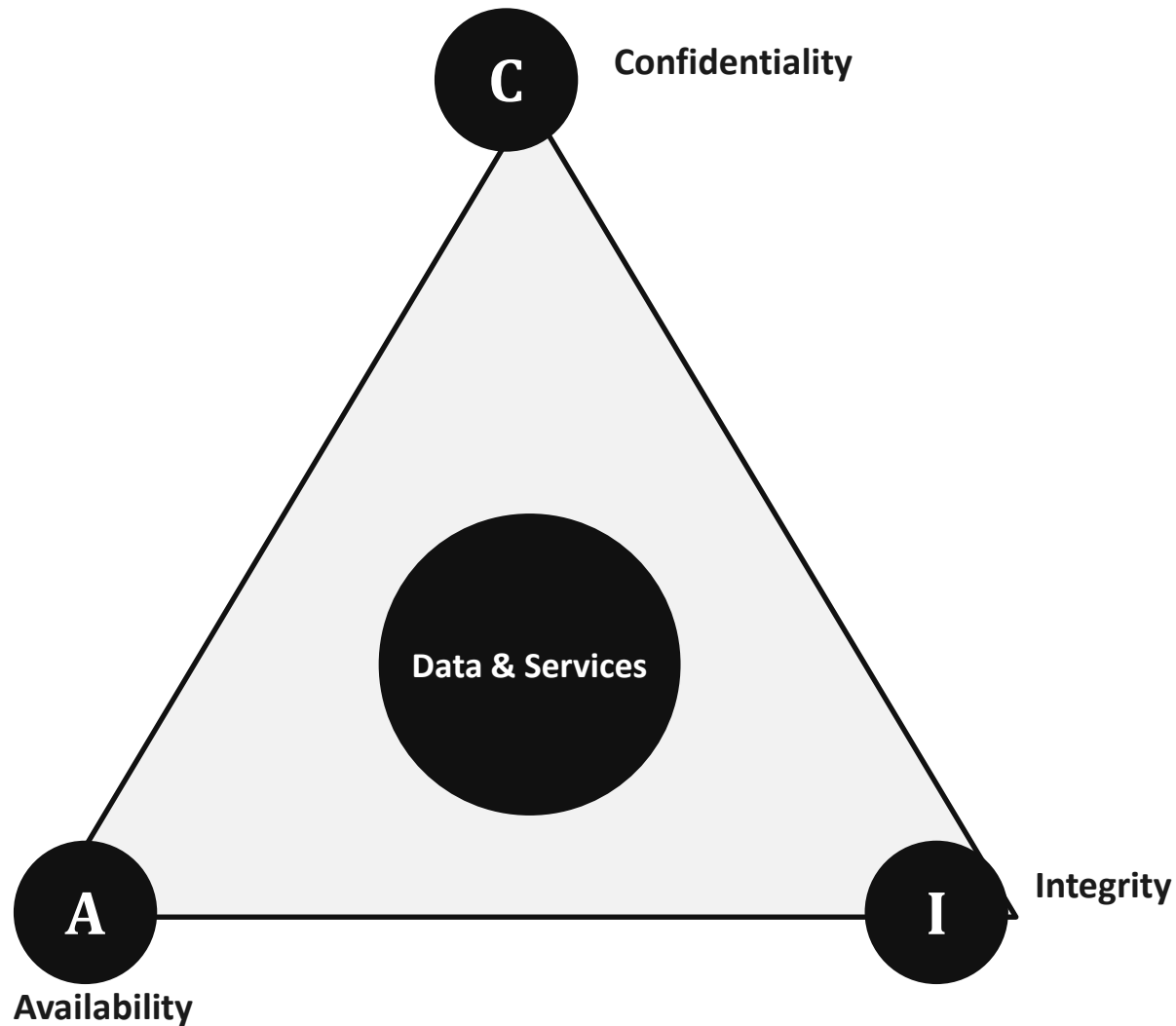
- Forces a systematic check: every goal, in every state, with every type of safeguard
- Reminds technical teams that policy and education are safeguards too
- Useful as a gap-analysis checklist: “Which cells have no control at all?”
- Simple enough to explain to non-technical managers



Limitations

- Covers the three dimensions of security but omits detailed guidelines and policies that direct how controls are implemented
- Viewing it from a single perspective is a weakness — e.g., thinking only about technology controls
- Treats C, I and A as sufficient; modern practice adds privacy, authenticity, accountability and more
- Needs a full risk-management process to decide which cells matter most

The C.I.A. Triad



Confidentiality

Only authorized people or systems can see the information



Integrity

Information is whole, complete and uncorrupted



Availability

Authorized users can access information when needed, in a usable format

The triad has expanded into a more comprehensive list of critical characteristics of information — covered in the next slides.

Confidentiality

An attribute of information that describes how data is protected from disclosure or exposure to unauthorized individuals or systems.

Limit access to those who need it; prevent access by those who do not. Common measures:



Information classification



Secure document & data storage



General security policies



Educating custodians & end users



Cryptography (encryption)



Examples of breaches

- An employee emails a customer list to a personal account
- A laptop with unencrypted patient records is stolen
- A misconfigured cloud storage bucket is left open to the internet
- Someone reads a password on a sticky note (“shoulder surfing”)
- Value is lost the moment information is disclosed — it cannot be “un-disclosed”

Integrity

An attribute of information that describes how data is whole, complete and uncorrupted.

- Integrity is threatened when information is exposed to corruption, damage, destruction, or other disruption of its authentic state
- Corruption can occur while information is being entered, stored or transmitted
- Causes include malware, hardware faults, software bugs and human error — not only attackers
- **Common controls:** hashing and checksums, digital signatures, input validation, access controls, version control and backups

How a hash detects change

Original: “Pay \$100 to Alice”

SHA-256 → 5f1c...a92e



Altered: “Pay \$900 to Alice”

SHA-256 → c07d...41b8

Changing one character produces a completely different hash. Comparing hashes reveals tampering. You will do this yourself in Lab 2.

Hash values abbreviated for illustration

Availability

An attribute of information that describes how data is accessible and correctly formatted for use without interference or obstruction.

- Users — people or other systems — have access to the information in a usable format
- Availability does not mean access for any user; it means access when needed by authorized users
- **Threats:** denial-of-service attacks, ransomware, hardware failure, power loss, natural disasters
- **Controls:** redundancy, backups, patching, capacity planning, disaster recovery and business continuity plans

What “the nines” really mean

99% 3.65 days downtime / year

99.9% 8.76 hours downtime / year

99.99% 52.6 minutes downtime / year

99.999% 5.26 minutes downtime / year

Calculated on a 365-day year (8,760 hours).

Beyond the Triad: Critical Characteristics



Privacy

Information is used only in ways approved by the person who provided it



Identification

A system can recognize an individual user by a label such as a user name



Authentication

Verification that a user or system is who or what it claims to be



Authorization

Matching an authenticated entity to the assets and access levels it may use



Accountability

Every action can be attributed to a named person or process; also called auditability



Plus C · I · A

Confidentiality, integrity and availability remain the foundation

Privacy

In the context of information security, the right of individuals or groups to protect themselves and their information from unauthorized access, providing confidentiality.



What privacy means in InfoSec

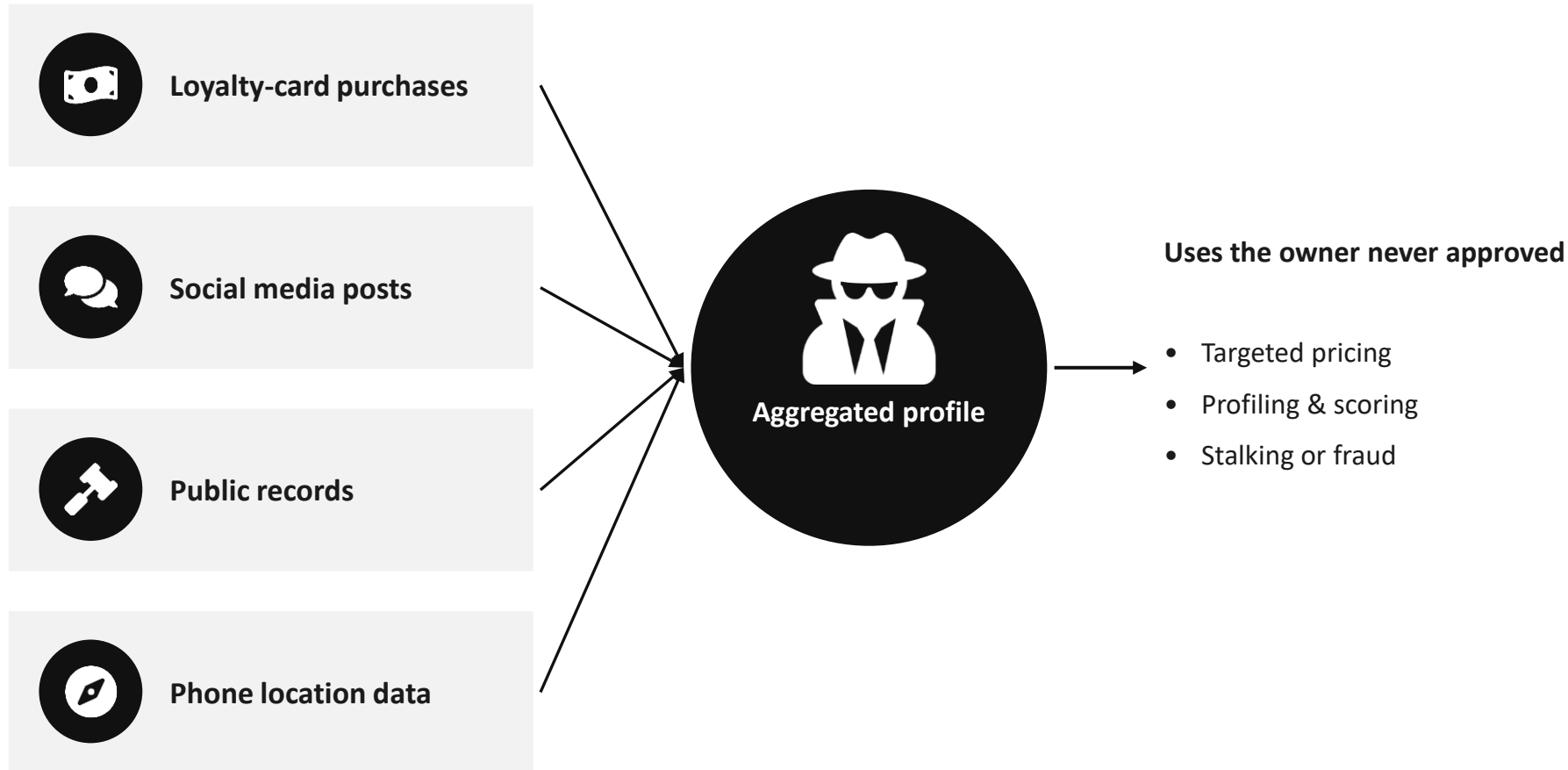
- Information collected, used and stored by an organization should be used only for the purposes stated to the data owner when it was collected
- It does NOT mean freedom from observation (the everyday meaning)
- It means the information will be used only in ways approved by the person who provided it



Why managers must care

- Privacy laws (e.g., GDPR in the EU, HIPAA for U.S. health data) impose legal duties and heavy fines
- Customer trust depends on honoring the purposes stated at collection
- Confidentiality is a tool; privacy is the obligation it helps fulfill

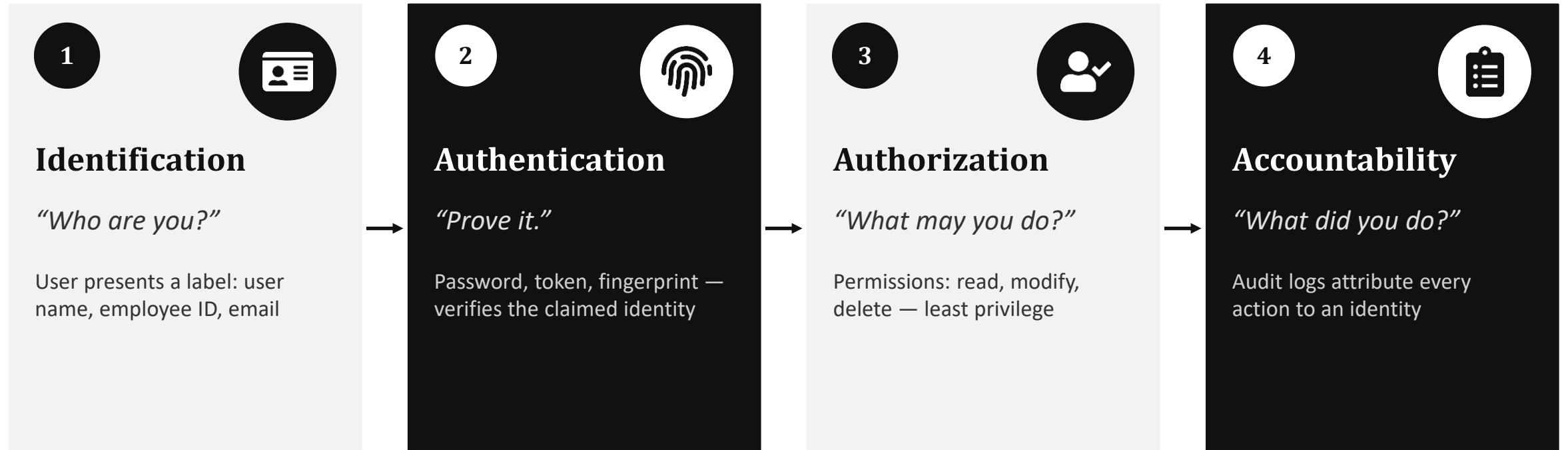
Information Aggregation



Key points

- Many organizations collect, swap and sell personal information as a commodity
- Combining data from several sources creates databases the original owners never agreed to — or even know about
- Each source alone may seem harmless; together they reveal a great deal

The Access Control Chain



Walk-through: Aziza types "aziza.k" (identification), enters her password and a phone code (authentication), is allowed to view but not edit payroll (authorization), and the system logs "aziza.k viewed payroll 09:14" (accountability).

Identification & Authentication

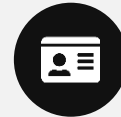
Definitions

- **Identification:** the mechanism whereby unverified entities who seek access to a resource provide a label by which they are known to the system
- **Authentication:** the mechanism that requires validation and verification of an unauthenticated entity's purported identity
- Identification and authentication together establish the level of access, or authorization, a person is granted



Something you know

Password, passphrase, PIN



Something you have

Smart card, phone app, hardware token



Something you are

Fingerprint, face, iris, voice

Multi-factor authentication (MFA) combines two or more DIFFERENT factor types. A password plus a PIN is still one factor; a password plus a phone code is two.

Authorization & Accountability



Authorization

- Matches an authenticated entity to a list of information assets and corresponding access levels
- Defines what the user has been explicitly permitted to do: access, modify or delete
- Guided by least privilege and need-to-know



Accountability (auditability)

- Ensures all actions — authorized or unauthorized — can be attributed to an authenticated identity
- Most commonly associated with system audit logs
- Deters misuse and supports investigations

Sample audit log

Time	User	Action	Object	Result
09:14:02	aziza.k	READ	payroll_2026.xlsx	Allowed
09:16:40	aziza.k	MODIFY	payroll_2026.xlsx	Denied
11:02:17	b.tursunov	DELETE	vendor_list.csv	Allowed
23:48:55	admin	EXPORT	customers.db	Allowed

Discuss: Which entries deserve investigation? Why is the 23:48 export by a shared “admin” account a problem for accountability?

Video: What Is the CIA Triad?



IBM Technology — “What is the CIA Triad” with Jeff Crume

[Click the play button or this link to watch](#)

Watch for

- How each letter becomes a question to ask before a project goes live
- Examples of controls for confidentiality, integrity and availability
- Where the three goals conflict with each other



After the video

In pairs: pick one app you use daily. Name one control for each of C, I and A that the app uses — and one it should add.

Knowledge Check: Which Characteristic Is Affected?

1

A hospital's patient portal is offline for six hours after a power failure.

Answer: Availability

2

An attacker changes the bank account number on a supplier's invoice.

Answer: Integrity

3

A clerk sends a spreadsheet of salaries to the wrong email distribution list.

Answer: Confidentiality

4

Several staff share one login, so no one can tell who deleted a file.

Answer: Accountability (and identification)

5

A company sells customer emails to advertisers without consent.

Answer: Privacy

6

A former employee's account still has access to the finance share.

Answer: Authorization

PART 2

Threats and Attacks

The vocabulary of risk and the twelve categories of threats every manager must understand

02

Know the Enemy, Know Yourself

“One who knows the enemy and knows himself will not be in danger in a hundred battles.”

— Sun Tzu, c. 500 BC



Know yourself

- Be familiar with the information assets to be protected
- Know the systems, mechanisms and methods used to store, transport, process and protect them
- This is why asset inventory comes first (Lab 1)



Know your enemy

- Understand the threats your organization faces
- Who might attack, why, and how — plus non-human threats such as failures and disasters
- This is the purpose of threat analysis (Lab 3)

The Vocabulary of Risk



Asset

The organizational resource being protected — data, systems, people, reputation



Threat

A potential risk to an asset; a category of objects, people or events that could cause harm



Threat agent

The specific instance of a threat — a person, group or event that causes harm



Vulnerability

A potential weakness in an asset or its defensive control system(s)



Exploit

A technique used to compromise a system by taking advantage of a vulnerability



Attack

An intentional or unintentional act that can damage or otherwise compromise information and supporting systems



Loss

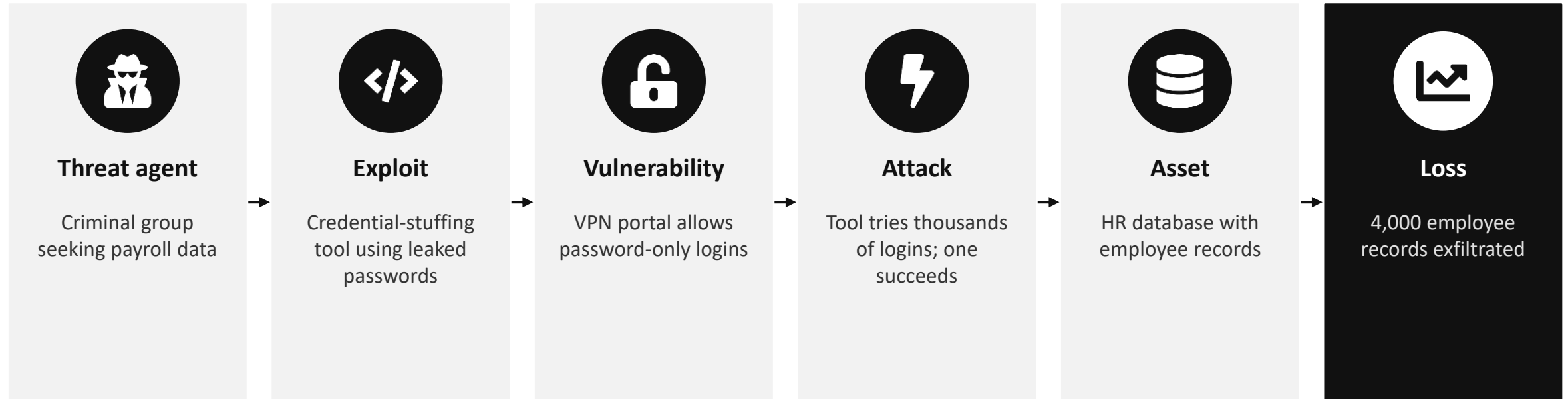
A single instance of an asset suffering damage, destruction, unintended modification or disclosure



Control

A safeguard or countermeasure that reduces the chance or impact of a loss

Anatomy of an Attack



Where could a control have broken the chain?

MFA on the VPN (removes the vulnerability) · login rate-limiting and alerts (detects the attack) · encryption and least privilege on the HR database (limits the loss) · user awareness of password reuse (reduces the exploit's success).

Fictional scenario for teaching purposes

The 12 Categories of Threats

Category of threat	Attack examples
Compromises to intellectual property	Piracy, copyright infringement
Deviations in quality of service	ISP, power or WAN service problems
Espionage or trespass	Unauthorized access and/or data collection
Forces of nature	Fire, floods, earthquakes, lightning
Human error or failure	Accidents, employee mistakes
Information extortion	Blackmail, information disclosure, ransomware

Category of threat	Attack examples
Sabotage or vandalism	Destruction of systems or information
Software attacks	Viruses, worms, macros, denial of service
Technical hardware failures or errors	Equipment failure
Technical software failures or errors	Bugs, code problems, unknown loopholes
Technological obsolescence	Antiquated or outdated technologies
Theft	Illegal confiscation of equipment or information

Categories overlap: a single incident, such as ransomware delivered by phishing, can involve human error, software attack and information extortion at once.

Compromises to Intellectual Property



Intellectual property (IP): creation, ownership and control of original ideas and their representation — trade secrets, copyrights, trademarks and patents.

- IP is protected by copyright and other laws; it carries the expectation of proper attribution and may require permission for use
- The unauthorized appropriation of IP constitutes a threat to information security
- **Software piracy:** unlawful use or duplication of software-based IP, including installing more copies than the license allows
- **Protection mechanisms:** license keys, user registration, online activation, digital watermarks, and enforcement by groups such as the Business Software Alliance (BSA)



Management angle

- Employees installing unlicensed software expose the organization to legal liability
- Trade secrets leaving with departing staff is a major IP risk
- Controls: software asset management, acceptable-use policy, NDAs, data loss prevention

Deviations in Quality of Service



A product or service is not delivered as expected. Information systems depend on many interdependent support systems — any of which can be interrupted.

- Dependencies include power grids, data and telecom networks, parts suppliers, service vendors — even janitorial staff and garbage haulers
- Interruptions come from severe weather, employee illness and other unforeseen events
- Irregularities in internet service, communications and power can dramatically affect availability



Internet service
issues



Communications &
other service
providers



Power irregularities

Power irregularities

- **Spike:** momentary increase in voltage
- **Surge:** prolonged increase
- **Sag:** momentary decrease
- **Brownout:** prolonged drop in voltage
- **Fault:** momentary complete loss
- **Blackout:** prolonged total loss
- **Controls:** UPS, surge protection, generators, SLAs with providers

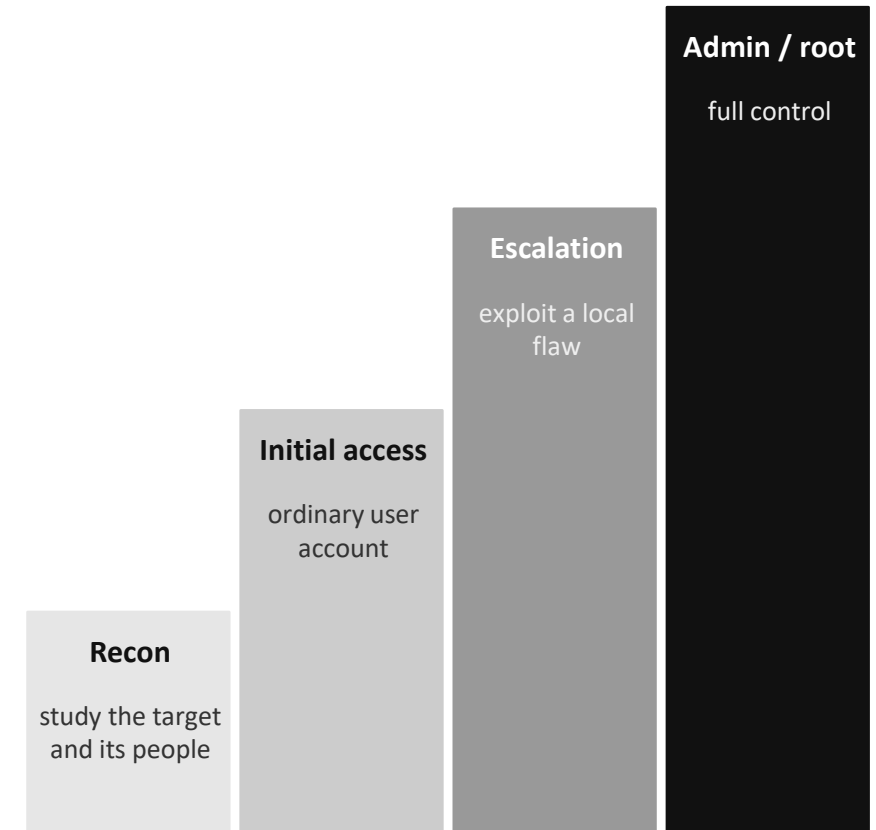
Espionage or Trespass



An unauthorized person gains access to information an organization is trying to protect. When techniques cross a legal or ethical threshold, it is industrial espionage.

- Ranges from shoulder surfing to sophisticated intrusions; competitive intelligence is legal, espionage is not
- **Expert hackers** spend long hours studying targets and use skill, guile or fraud to bypass controls
- **Unskilled attackers** (“script kiddies”, “packet monkeys”) use tools written by others
- Once inside, attackers seek privilege escalation to gain administrator or root control

Privilege escalation



Password Attacks

Password attacks fall under espionage or trespass just as lock-picking falls under breaking and entering. Guessing or reverse-calculating a password is called cracking.



Brute force

Try every possible combination of characters. Guaranteed to succeed eventually — length makes it impractical.

Defense: long passwords, logout, rate limiting



Dictionary attack

Try a list of common words and passwords, plus predictable variations (P@ssw0rd).

Defense: block common passwords, passphrases



Rainbow tables

Pre-computed tables of hashes let attackers look up a stolen hash instead of computing it.

Defense: salted, slow hashing (bcrypt, Argon2)

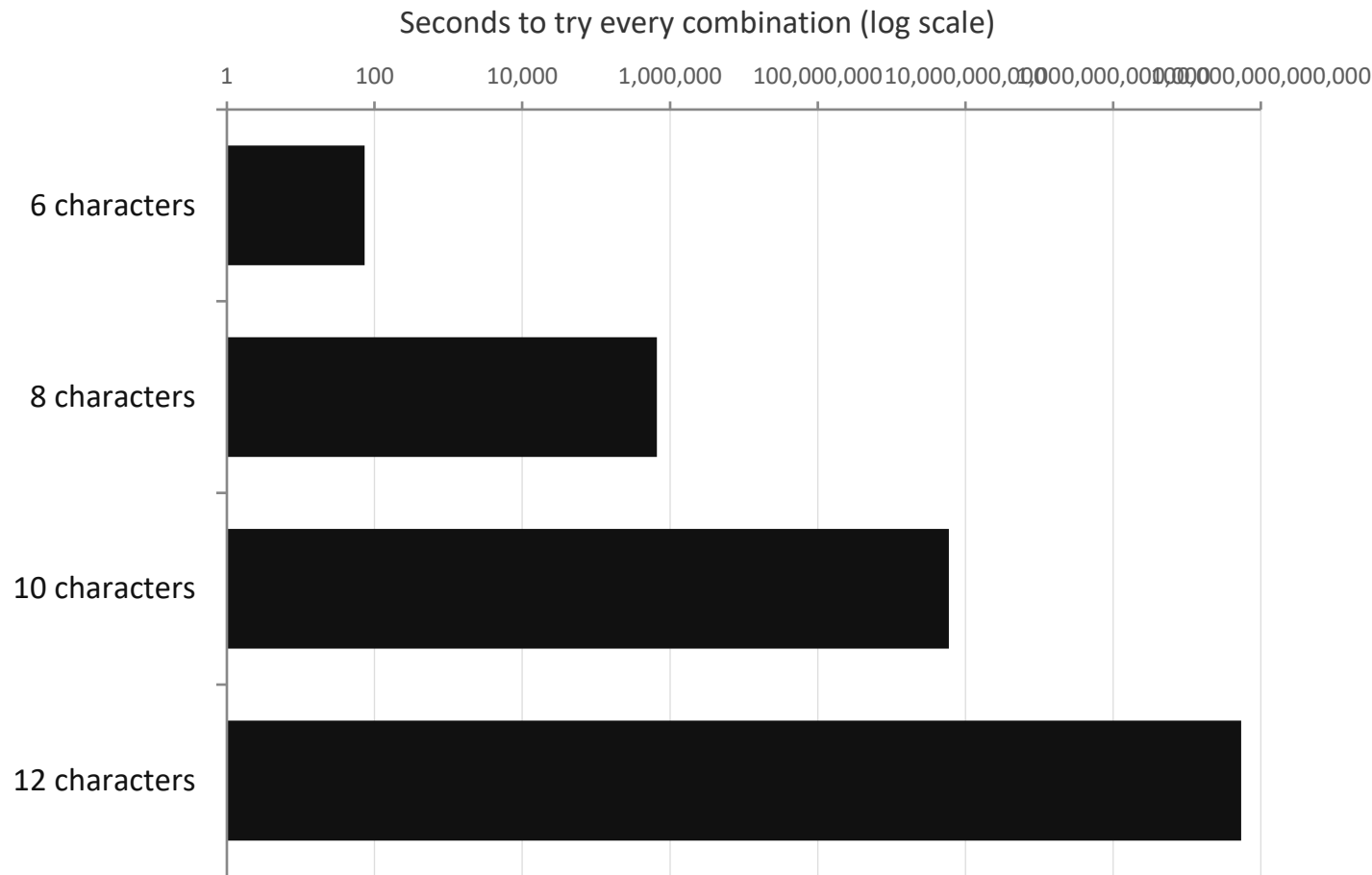


Social engineering

Simply ask for the password — posing as IT support, a manager or a vendor.

Defense: awareness, “IT will never ask”, MFA

Why Length Matters: Time to Exhaust a Password Space



6 chars ~1 minute

8 chars ~8 days

10 chars ~190 years

12 chars ~1.7 million years

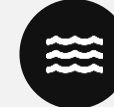
Assumptions: all 95 printable ASCII characters; an offline attacker making 10 billion guesses per second. Eight lowercase letters only: ~21 seconds. Real passwords are weaker because people choose predictable patterns.

Forces of Nature

- Among the most dangerous threats: they occur with little warning and are beyond human control
- They cannot be avoided — organizations must limit damage and prepare contingency plans for continued operations
- **Force majeure** (“superior force”) covers forces of nature as well as civil disorder and acts of war
- Most can only be mitigated through insurance, though careful facility design and placement reduce the likelihood of damage



Fire



Flood



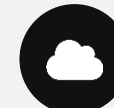
Earthquake



Lightning



Tornado / windstorm



Hurricane / typhoon



Tsunami



Landslide / mudslide



Electrostatic discharge



Dust contamination

Human Error or Failure



Acts performed without intent or malicious purpose, or in ignorance, by an authorized user.

- When people use information systems, mistakes happen — and people fail to follow established policy
- Causes: inexperience, improper training, incorrect assumptions, fatigue and time pressure
- Employees are among the greatest threats because they are the threat agents closest to the information
- Often prevented with training, ongoing awareness activities, and controls (e.g., confirmation prompts, the four-eyes principle)

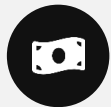


Everyday examples

- Emailing sensitive data to the wrong recipient
- Misconfiguring a cloud storage bucket as public
- Deleting a production database instead of a test copy
- Clicking a malicious link or attachment
- Entering data incorrectly (typing 900 instead of 100)

The Social Engineering Toolkit

Social engineering: using social skills to convince people to reveal access credentials or other valuable information to an attacker.



Advance-fee fraud

Victim is promised a large reward for paying a small fee first (the “419” scam)



Phishing

Mass emails impersonating trusted brands to steal credentials or deliver malware



Spear phishing

Phishing tailored to one person or group using researched personal details



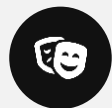
URL manipulation

Look-alike links such as paypa1.com or links that hide the real destination



Website forgery

Fake login pages that copy the look of legitimate sites



Pretexting

Attacker invents a scenario (“I’m from IT”) to justify the request



Vishing & smishing

The same tricks by phone call or SMS text message



Business email compromise

Impersonating executives or suppliers to redirect payments

Video: Phishing Explained



IBM Technology — “Phishing Explained” with Jeff Crume

[Click the play button or this link to watch](#)

Watch for

- The difference between phishing, spear phishing and whaling
- Psychological triggers attackers rely on
- Practical ways to spot and report a suspicious message



After the video

Which controls here are technical, and which are managerial? Who in the three communities of interest owns each one?

Information Extortion: The WannaCry Case



Information extortion (cyberextortion): an attacker steals or locks up information and demands compensation for its return or non-disclosure. Today it is dominated by ransomware, which encrypts data and demands payment for the key.

14 Mar 2017



Microsoft releases patch MS17-010 for the SMB flaw

14 Apr 2017



“Shadow Brokers” leak the NSA-developed EternalBlue exploit

12 May 2017



WannaCry worm spreads worldwide via unpatched Windows systems

12 May 2017



A researcher registers a “kill switch” domain, slowing the spread

Aftermath



200,000+ computers in 150+ countries; hospitals, factories, telecoms hit



Management lesson: a patch was available about two months before the outbreak. Most victims were not hit by a sophisticated zero-day — they were hit because patch management, asset inventory and legacy-system decisions were not managed.

Video: WannaCry — Ransomware Causing Chaos Globally



BBC News — “Cyber attack: Ransomware causing chaos globally”

[Click the play button or this link to watch](#)

Watch for

- Which types of organizations were affected
- How the business impact went beyond “IT problems”
- Which of the 12 threat categories you can identify



After the video

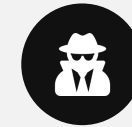
You are the CISO of a hospital on 12 May 2017. List your first three decisions — and who you must inform.

Sabotage or Vandalism



Deliberate sabotage of a computer system or business, or acts of vandalism to destroy an asset or damage the image of an organization.

- Ranges from petty vandalism by employees to organized sabotage against an organization
- Website defacement erodes consumer confidence, diminishing sales, net worth and reputation
- **Online activism (hacktivism):** interfering with or disrupting systems to protest an organization's operations, policies or actions
- **Cyberterrorism and cyberwarfare:** politically motivated attacks on critical infrastructure, sometimes by or for nation-states
- **Positive online activism:** social media campaigns, petitions and awareness efforts that stay within the law



Insider sabotage

- Disgruntled employees are a classic source of sabotage
- Warning signs: recent termination notice, disputes, access outside normal duties
- Controls: prompt de-provisioning, separation of duties, monitoring of privileged users, backups

Software Attacks

Deliberate software attacks occur when an individual or group designs and deploys software to attack a system — to overwhelm its processing capabilities or to gain access by hidden means.



Malware

Viruses (need a host and user action), worms (self-replicate across networks), Trojan horses (hide inside useful-looking software), polymorphic threats (change their code to evade detection), and hoaxes



Back doors

Hidden access points that bypass normal controls — also called trap doors or maintenance hooks, sometimes left by developers



DoS & DDoS

Flood a target with requests so legitimate users cannot be served; DDoS uses many compromised machines (a botnet)



E-mail attacks

Spam, mail bombs that flood a mailbox, and social engineering delivered by email



Communications interception

Packet sniffers, spoofing, pharming (redirecting to fake sites) and man-in-the-middle attacks

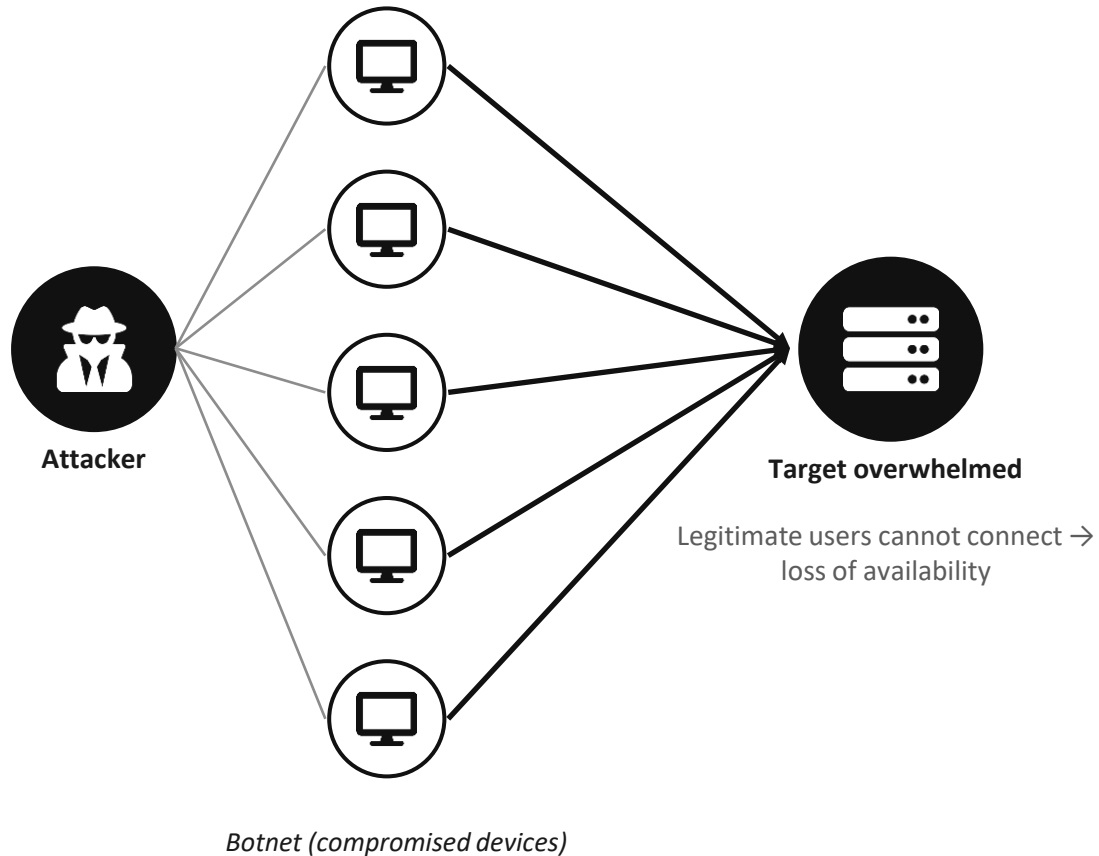


Ransomware

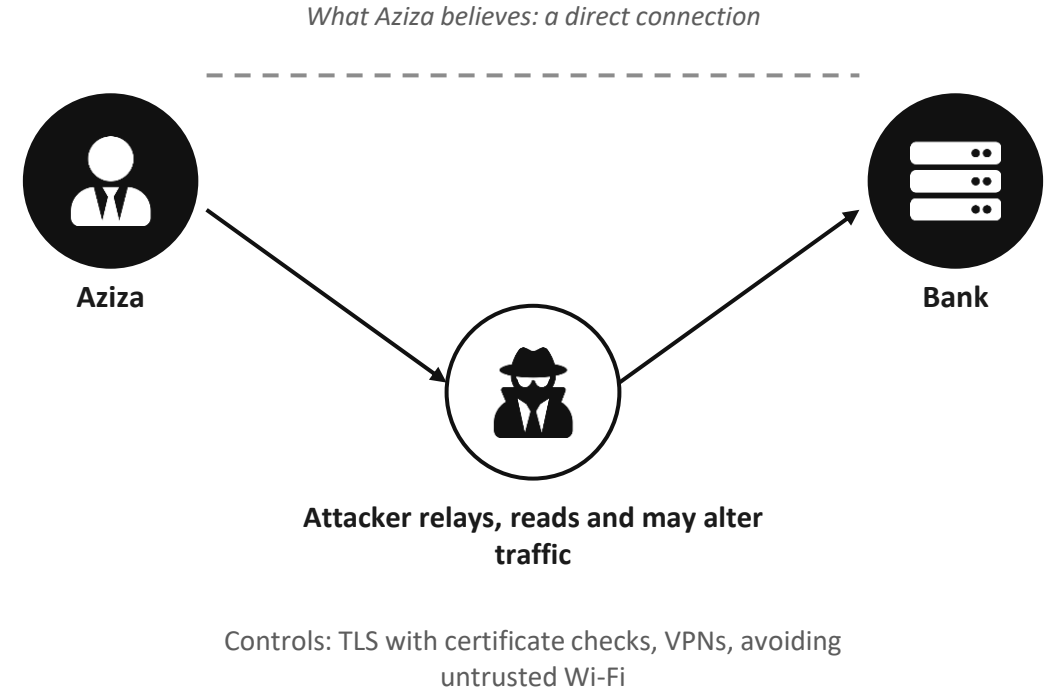
Malware that encrypts data and demands payment — overlaps with information extortion

Two Network Attacks, Visualized

Distributed denial of service (DDoS)



Man-in-the-middle (MITM)

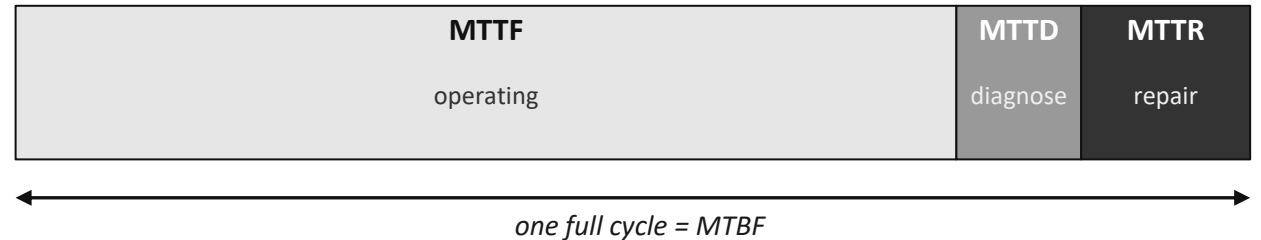


Technical Hardware Failures or Errors

- Occur when a manufacturer distributes equipment containing a known or unknown flaw
- Can cause systems to perform outside expected parameters — unreliable service or lack of availability
- **MTBF** (mean time between failure) presumes the item can be repaired or returned to service
- **MTTF** (mean time to failure) presumes the item must be replaced
- **MTTD / MTTR**: mean time to diagnose / mean time to repair

From a repair standpoint

$$\text{MTBF} = \text{MTTF} + \text{MTTD} + \text{MTTR}$$



Worked example:

A storage array runs 2,000 h before failing (MTTF), takes 4 h to diagnose and 12 h to repair.

MTBF = 2,000 + 4 + 12 = 2,016 h. Availability $\approx 2,000 \div 2,016 \approx 99.2\%$

Technical Software Failures or Errors



Large quantities of code are written, debugged, published and sold before all their bugs are detected and resolved.

- Combinations of certain software and hardware can reveal new failures — from bugs to untested failure conditions
- Some “bugs” are purposeful shortcuts left by programmers that bypass security checks to speed up testing — known as trap doors
- Vulnerability databases and advisories track known flaws — e.g., the CVE list, the U.S. National Vulnerability Database and vendor advisories; Bugtraq was a long-running mailing list for this purpose
- Sound development practices, change control and quality assurance greatly improve software security



Secure development basics

- Security requirements defined at design time
- Code review and automated security testing
- Dependency management — know your third-party components
- Patch management for software you buy
- Change control before anything reaches production

OWASP Top 10:2025 — Critical Web Application Risks

A01 Broken Access Control

A02 Security Misconfiguration

A03 Software Supply Chain Failures (new)

A04 Cryptographic Failures

A05 Injection

A06 Insecure Design

A07 Authentication Failures

A08 Software or Data Integrity Failures

A09 Security Logging & Alerting Failures

A10 Mishandling of Exceptional Conditions (new)



What changed

- The textbook cites the 2017 list; OWASP released the 2025 edition in November 2025
- Two new categories: supply chain failures and mishandling of exceptional conditions
- Server-side request forgery was folded into broken access control
- Focus shifted from individual coding errors to root causes

Source: owasp.org/Top10/2025

The Deadly Sins of Software Security



Web application sins

- SQL injection
- Web server-related vulnerabilities
- Web client-related vulnerabilities (XSS)
- Magic URLs, predictable cookies, hidden form fields



Cryptographic sins

- Use of weak password-based systems
- Weak random numbers
- Using the wrong cryptography



Networking sins

- Failure to protect network traffic
- Improper use of PKI, especially SSL/TLS
- Trusting network name resolution



Implementation sins

- Buffer overflow; format string problems; integer overflows
- C++ catastrophes; catching exceptions; command injection
- Failure to handle errors; information leakage; race conditions
- Poor usability; not updating easily; too much privilege
- Failure to protect stored data; sins of mobile code

Technological Obsolescence



Antiquated or outdated infrastructure leads to unreliable and untrustworthy systems.

- When technology becomes outdated, there is a risk of losing data integrity from attacks
- Proper planning should prevent technology from becoming obsolete — when obsolescence is clear, management must act immediately
- **Classic case:** Microsoft Windows XP — extended support ended in April 2014, yet it was still widely used when WannaCry struck in 2017
- **Current case:** Windows 10 reached end of support on 14 October 2025 — unpatched systems accumulate unfixable vulnerabilities



Managing lifecycle risk

- Maintain an asset inventory with end-of-support dates
- Budget for replacement before end of life
- Isolate legacy systems that cannot be replaced
- Consider extended-support contracts as a stop-gap

Theft



The illegal taking of another's property — physical, electronic or intellectual. The value of information is diminished when it is copied without the owner's knowledge.

- Physical theft can be controlled easily with a wide variety of measures: locked doors, trained security personnel, alarm systems
- Electronic theft is a more complex problem — the original stays in place, so the loss may go unnoticed
- Theft often overlaps with software attacks, espionage or trespass, information extortion and compromises to IP
- **Common forms today:** stolen laptops and phones, data exfiltration, credential theft, and cryptocurrency theft



Controls against theft

- Full-disk encryption on all portable devices
- Remote wipe and device tracking
- Data loss prevention (DLP) tools
- Monitoring for unusual downloads
- Physical controls: cable locks, badges, CCTV

Knowledge Check: Name the Threat Category

1

A storm knocks out power to the data center for two days.

Answer: Forces of nature (and deviation in QoS)

2

An employee installs pirated design software on a work laptop.

Answer: Compromises to intellectual property

3

Criminals encrypt all file servers and demand bitcoin.

Answer: Information extortion (via software attack)

4

A dismissed admin deletes the backup archive on the way out.

Answer: Sabotage or vandalism

5

The billing system still runs on an OS with no security patches.

Answer: Technological obsolescence

6

A finance clerk wires money after a fake “CEO” email.

Answer: Human error or failure (social engineering)

PART 3

Management and Leadership

03

What managers do, how leading differs from managing, and the functions that turn security goals into results

What Is Management?

Management is the process of achieving objectives using a given set of resources. A **manager** marshals and administers resources, coordinates the completion of tasks, and handles the many roles needed to reach the objectives.



Informational

Collecting, processing and using information that affects task completion

Monitor

Disseminator

Spokesperson



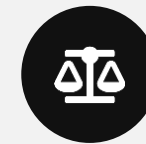
Interpersonal

Interacting with superiors, subordinates, outside stakeholders and others

Figurehead

Leader

Liaison



Decisional

Selecting from alternatives, resolving conflicts, allocating resources

Entrepreneur

Disturbance handler

Resource allocator

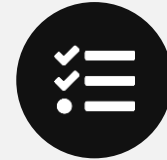
Negotiator

Leadership vs. Management



A leader...

- Influences employees so that they are willing to accomplish objectives
- Is expected to lead by example
- Demonstrates personal traits that instill a desire in others to follow
- Provides purpose, direction and motivation
- Focus: people, vision, change



A manager...

- Administers the resources of the organization
- Creates budgets and authorizes expenditures
- Recruits, hires, evaluates and terminates employees
- Plans, organizes and controls work to meet objectives
- Focus: resources, processes, results



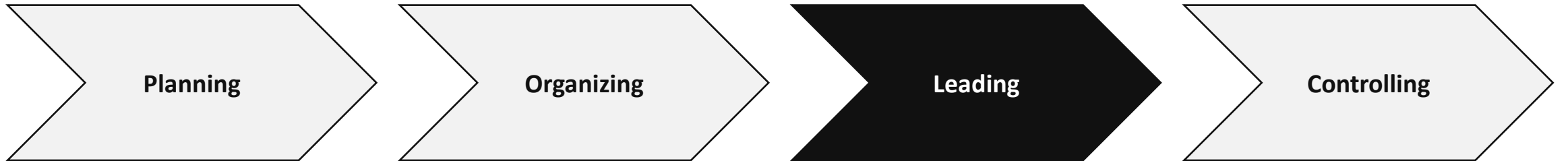
Effective managers can also be effective leaders — the best InfoSec managers run the program AND inspire people.

Two Views of the Management Functions

Traditional: POSDC



Popular: POLC



POLC merges staffing and directing into a single “leading” function. This course uses POLC.

Planning: From Strategy to Daily Operations

Planning is the process of developing, creating and implementing strategies to accomplish objectives.

- **Goals** and objectives are set, then broken into strategies, plans and tasks
- Each level of plan supports the level above it
- InfoSec plans must align with the organization's overall strategic plan



Security example

A strategic goal of customer trust drives a tactical MFA project, which drives operational tasks such as daily log review and help-desk procedures.

Strategic

3–5+ years · executives

Long-term direction: e.g., “become a trusted provider of digital banking”

Tactical

1–3 years · middle managers

Medium-term projects: e.g., “implement MFA for all customers by next year”

Operational

Daily to monthly · supervisors & staff

Day-to-day tasks: e.g., “review failed-login report every morning”

Organizing, Leading and Controlling



Organizing

The management function dedicated to structuring resources to support the accomplishment of objectives.

- Define roles and reporting lines
- Assign responsibilities (who owns each asset?)
- Group tasks into teams
- InfoSec: where the security team sits, RACI charts



Leading

Encourages implementation of planning and organizing; supervises employee behavior, performance, attendance and attitude while ensuring completion of tasks.

- Motivation and communication
- Individual and group behavior
- InfoSec: building a security culture, not just enforcing rules

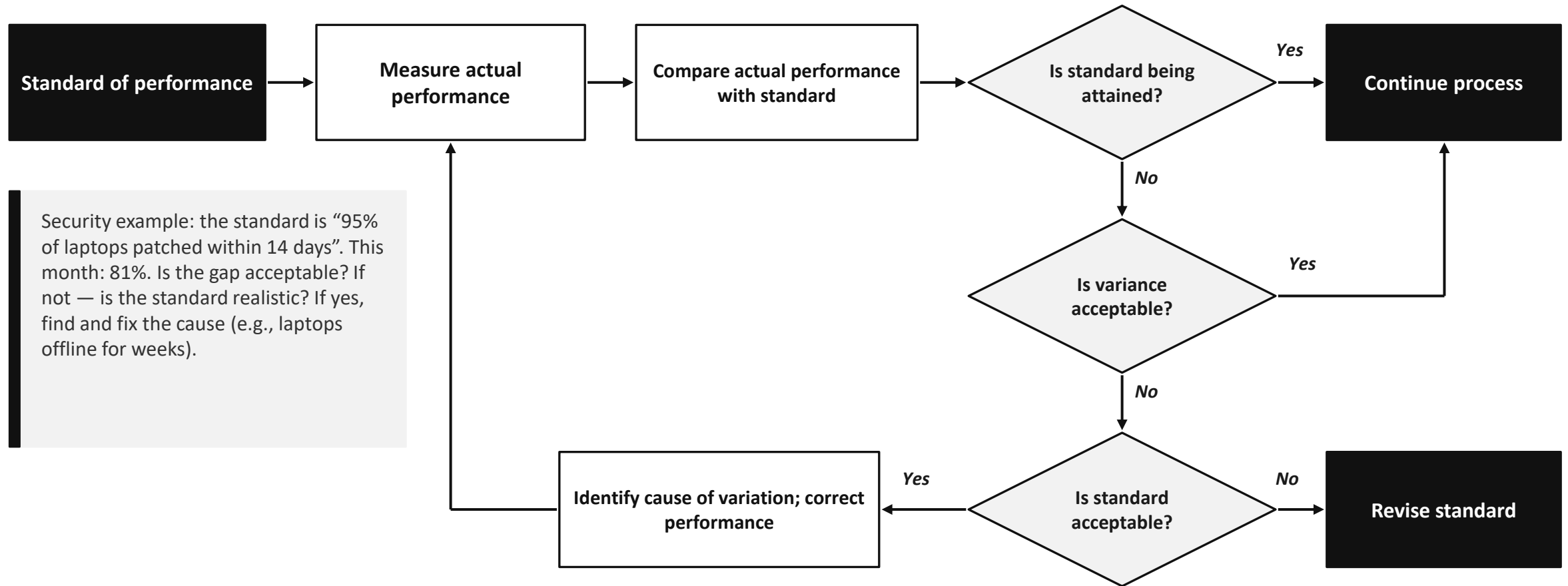


Controlling

Ensures the validity of the plan — sufficient progress is made, impediments are resolved, and no additional resources are needed.

- Set standards, measure, compare, act
- InfoSec: metrics, audits, reviews of control effectiveness

The Control Process



Governance

Governance: the set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.



Strategic direction



Objectives achieved



Risks managed



**Resources used
responsibly**

- Governance emphasizes escalating the importance of InfoSec to the uppermost levels of the organization and giving it an appropriate level of management
- Governance asks “are we doing the right things?”; management asks “are we doing things right?”
- Frameworks such as ISO/IEC 27001, COBIT and the NIST Cybersecurity Framework 2.0 (which added a “Govern” function) support InfoSec governance

Solving Problems: A Five-Step Approach

1

Recognize and define the problem

State it precisely. “Too many phishing clicks” vs. “12% of staff clicked last month’s simulation”

2

Gather facts and make assumptions

Collect data; state assumptions explicitly so they can be tested

3

Develop possible solutions

Brainstorm widely before judging: training, email filtering, reporting button, MFA

4

Analyze and compare solutions

Use feasibility analyses: economic, technical, behavioral, political

5

Select, implement and evaluate

Choose, deploy, then measure — did the click rate actually fall?

Step 4 in Depth: Feasibility Analyses



Economic feasibility

- Do the benefits justify the costs?
- Cost-benefit analysis, total cost of ownership, budget availability



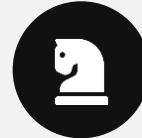
Technical feasibility

- Can we actually build and run it?
- Compatibility with existing systems, skills available, vendor maturity



Behavioral feasibility

- Will people accept and use it?
- User impact, training needs, likelihood of workarounds



Political feasibility

- Will the organization support it?
- Stakeholder support, competing priorities, who wins and who loses

A solution that is technically perfect but behaviorally or politically infeasible will fail — a recurring lesson in security management.

PART 4

Principles of Information Security Management

The six Ps: the specialized functions that set InfoSec management apart

04

The Six Ps of Information Security Management



- 1 Planning:** Design, creation and implementation of InfoSec strategies
- 2 Policy:** Organizational guidelines that dictate behavior
- 3 Programs:** Separately managed InfoSec operations, e.g., SETA
- 4 Protection:** Risk management activities, mechanisms, technologies and tools
- 5 People:** Security personnel, the security of personnel, and awareness
- 6 Projects:** Project management discipline applied to every element

P1 — InfoSec Planning

- An extension of the basic planning model covered earlier
- Includes the activities needed to design, create and implement InfoSec strategies
- InfoSec strategic plans must support the IT use and protection of information assets across the entire organization
- Therefore the CISO must work closely with all senior managers in developing InfoSec strategy

Types of InfoSec plans



Incident response planning



Business continuity planning



Disaster recovery planning



Policy planning



Personnel planning



Technology rollout planning



Risk management planning

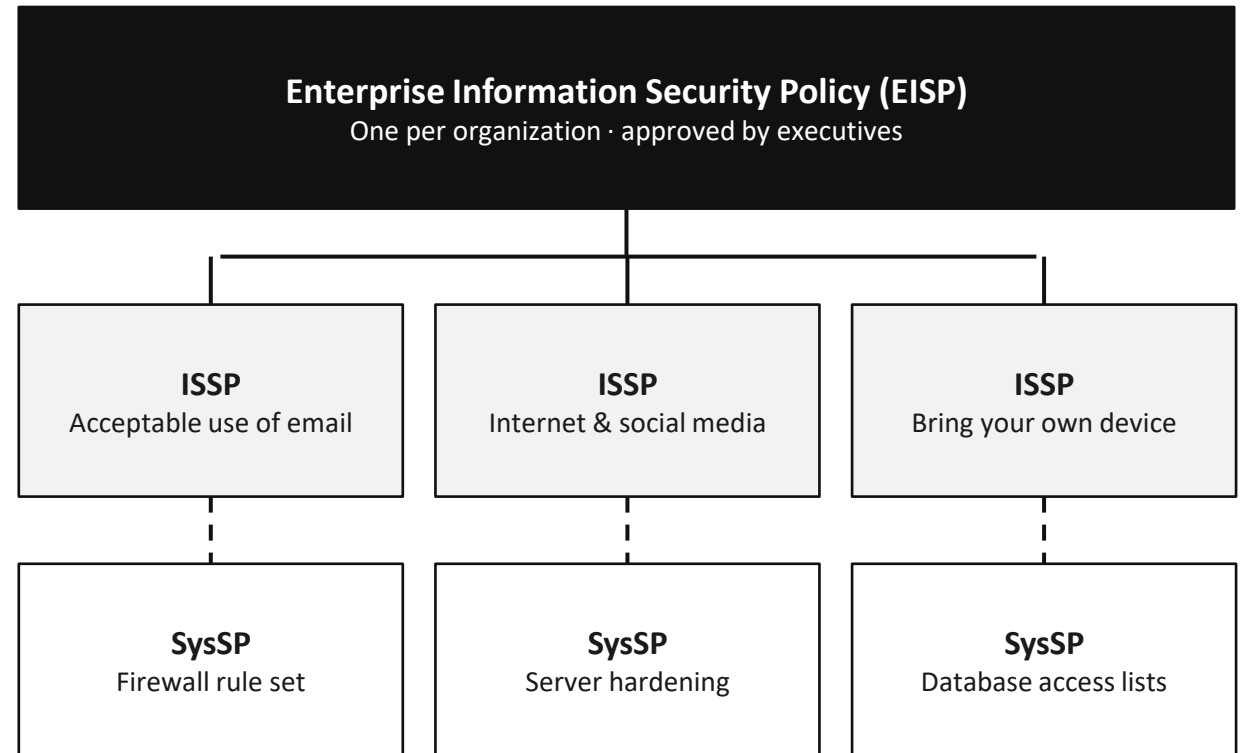


Security program planning
(incl. SETA)

P2 — Policy

Policy: a set of organizational guidelines that dictate certain behavior within the organization.

- **EISP** — sets the strategic direction, scope and tone for all security efforts
- **ISSP** — addresses specific areas of technology and guides employee use of them
- **SysSP** — specifies how particular systems must be configured and managed
- Policies must be written, distributed, read, understood, agreed to and uniformly enforced to be effective



Broad and strategic at the top; specific and technical at the bottom

P3 & P4 — Programs and Protection



Programs

- InfoSec operations that are specifically managed as separate entities
- **SETA program:** security education, training and awareness — the classic example
- Others: physical security program (fire, physical access, gates, guards), vulnerability management program, third-party risk program
- Each program has its own goals, budget, staff and metrics



Protection

- Executed through a set of risk management activities: risk assessment and risk control
- Also through protection mechanisms, technologies and tools
- Each mechanism represents management of specific controls within the overall security plan
- Examples: firewalls, encryption, access control, backups — chosen based on assessed risk

P5 & P6 — People and Projects



People

- People are the most critical link in the information security program
- **Security personnel:** hiring, training and retaining skilled security staff
- **Security of personnel:** background checks, separation of duties, secure onboarding and offboarding
- Plus the awareness side of SETA for every employee



Projects

- Apply thorough project management discipline to all elements of the InfoSec program
- Identify and control the resources applied to each project
- Measure progress and adjust the process as progress is made toward the goal
- Tools: scope, schedule, budget, milestones, work breakdown structures

Is Security a Process or a Project?

Information security is a process, not a project — yet each element of the program must be managed as a project. It is a continuous chain of projects.



Ongoing process (operations): monitoring, patching, access reviews, incident handling

Project

Defined start and end, specific deliverable, dedicated budget — e.g., deploy MFA by March

Process

Continuous and repeating, no end date — e.g., review access rights every quarter

InfoSec Management vs. General Business Management

Dimension	General business management	Information security management
Primary goal	Achieve business objectives: growth, profit, service	Secure operation of the organization; protect information assets
Core functions	Planning, organizing, leading, controlling (POLC)	POLC plus the six Ps: planning, policy, programs, protection, people, projects
Main “adversary”	Competitors and market conditions	Intelligent, adaptive threat agents plus failures and disasters
Measure of success	Visible outputs: revenue, market share, satisfaction	Often invisible: incidents that did not happen, risk kept within appetite
Scope	Usually a department or business unit	Cuts across every unit, supplier and system
Nature of work	Many initiatives end when goals are met	A continuous process delivered as a chain of projects

Summary: Key Takeaways (1 of 2)



From computer security to InfoSec

Because business and technology have become more fluid, the narrow idea of computer security has been replaced by the broader concept of information security.



Three communities of interest

InfoSec professionals, IT professionals and non-technical business managers must reach consensus on how to protect information.



C.I.A. and beyond

Confidentiality, integrity and availability — expanded with privacy, identification, authentication, authorization and accountability.



Know the threats

To make sound security decisions, management must be informed about threats to its people, applications, data and information systems.

Summary: Key Takeaways (2 of 2)



12 categories of threats

From compromises to IP and forces of nature to software attacks, obsolescence and theft — categories often overlap.



Attacks exploit vulnerabilities

A threat agent uses an exploit against a vulnerability where controls are absent or ineffective, causing a loss.



Build security into software

Sound development practices, change control and quality assurance greatly improve software security.



Leading ≠ managing

Leaders influence people to accomplish objectives; managers administer resources. POLC and POSDC describe management functions.



Plan at three levels

Strategic, tactical and operational planning, checked by the control process and directed by governance.



The six Ps

Planning, policy, programs, protection, people and projects focus InfoSec management on secure operation.

Key Terms to Know

Term	Meaning
Accountability	Actions attributable to an authenticated identity
Attack	Act that can compromise information or systems
Authentication	Verifying a claimed identity
Authorization	Matching an identity to permitted access
Availability	Accessible and usable when needed by authorized users
C.I.A. triad	Confidentiality, integrity, availability
Communities of interest	InfoSec, IT and general business groups
Confidentiality	Protection from unauthorized disclosure
Exploit	Technique used to compromise a system

Term	Meaning
Governance	Board and executive direction and oversight
Identification	Presenting a label known to the system
Integrity	Whole, complete and uncorrupted
McCumber cube	3-D CNSS model: goals × states × safeguards
POLC / POSDC	Functions of management
Privacy	Use only as approved by the data provider
Threat / threat agent	Potential danger / its specific instance
Vulnerability	Weakness in an asset or its controls
Six Ps	Planning, policy, programs, protection, people, projects

Review and Discussion Questions

1

Why must information security involve all three communities of interest rather than the IT department alone?

2

Using the McCumber cube, propose one control for the cell Integrity × Storage × Technology.

3

Explain the difference between a threat, a vulnerability and an exploit using your own example.

4

Which of the 12 threat categories applied to WannaCry? Justify each one.

5

Why is “availability” not the same as “accessible to everyone”?

6

Give an example of a person who is a leader but not a manager, and one who is a manager but not a leader.

7

Apply the control process to the standard “all staff complete security awareness training annually”.

8

How can information security be both a process and a project?

This Week's Labs



Lab 1

Information Asset Inventory & CIA Classification

- Build an inventory of 10 assets
- Rate C, I and A impact for each
- Map controls to McCumber cube cells

60–75 min · Objectives 1, 4



Lab 2

Integrity, Authentication & Password Strength

- Compute and compare SHA-256 hashes
- Analyze password length and keyspace
- Review MFA and IAAA on a real account

60–75 min · Objective 1



Lab 3

Threat Analysis Case Study & Six Ps Plan

- Classify incidents into the 12 categories
- Build threat → vulnerability → control chains
- Draft a one-page six Ps response plan

75–90 min · Objectives 2, 3, 5

References and Further Reading

- **Textbook:** Whitman, M. E., & Mattord, H. J. Management of Information Security (6th ed.), Chapter 1. Cengage.
- **Breach costs:** IBM Security. Cost of a Data Breach Report 2025.
- **Human element:** Verizon. 2025 Data Breach Investigations Report (DBIR).
- **Web risks:** OWASP Foundation. OWASP Top 10:2025 — owasp.org/Top10/2025
- **Models:** Committee on National Security Systems (CNSS); McCumber, J. (1991). Information Systems Security: A Comprehensive Model.
- **Governance:** NIST. Cybersecurity Framework (CSF) 2.0, 2024. ISO/IEC 27001:2022.
- **WannaCry:** Microsoft Security Bulletin MS17-010 (March 2017); public reporting by BBC News and Cloudflare Learning Center.
- **Videos:** IBM Technology — “What is the CIA Triad” and “Phishing Explained” (Jeff Crume); BBC News — “Cyber attack: Ransomware causing chaos globally”.

Questions?

*“Management is, above all, a practice where art, science and craft meet.”
— Henry Mintzberg*

BEFORE NEXT CLASS

- Complete and submit Labs 1–3
- Review the key terms and review questions
- Read Chapter 2 for next week

